



DSPM BEST PRACTICES CHEAT SHEET

Find sensitive data before attackers do

The do's and don'ts for six data security practices, from the first scan to the audit, with the AccuKnox setup page for each gap.

Sensitive data spreads faster than teams track it

More than half of cloud data is now sensitive, and most breached organizations had not encrypted it everywhere. Staff also feed that data into AI tools that security never approved.

54%

of cloud data was classified as sensitive in 2025, up from 47% in 2024.

Thales, 2025 Cloud Security Study.
cpl.thalesgroup.com

37%

of breached organizations encrypt sensitive data both at rest and in transit.

IBM, Cost of a Data Breach 2026.
newsroom.ibm.com

43%

of security incidents involved workers using unapproved AI tools, more than double the year before.

IBM Cost of a Data Breach 2026,
via Help Net Security.
helpnetsecurity.com

Four reasons sensitive data stays **exposed**



Copies outrun the inventory

Teams copy data into new buckets, databases and SaaS apps every week. The average enterprise now runs 85 SaaS applications. A list kept by hand misses the newest copy first.



A name hides the content

A bucket named logs can hold card numbers. Customer PII was 52% of the data stolen or exposed in 2026 breaches, at \$192 per record. Only a scan of the content shows it.



Encryption lacks context

Only 8% of organizations encrypt 80% or more of their cloud data. A posture check that cannot see which store holds PII cannot tell you which unencrypted store to fix first.



Findings have no owner

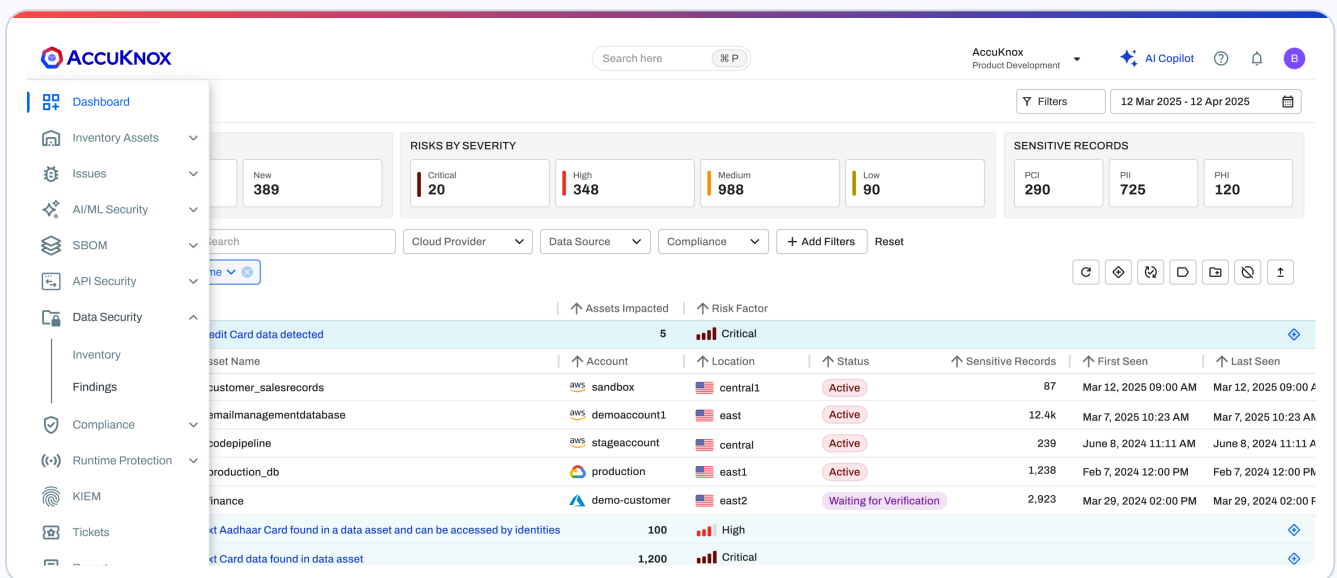
Breaches took 247 days on average to identify and contain in 2026. A data finding with no severity, SLA or ticket waits in the queue while the copy stays open.

Sources. 85 SaaS apps and 8%: Thales 2025 Cloud Security Study, [press release](#) and [blog](#). 52% and \$192: IBM Cost of a Data Breach 2026, via [Network World](#). 247 days: IBM Cost of a Data Breach 2026, via [Help Net Security](#).

Start here

Six practices close the data gap

Find each store, read what it holds, close the exposed ones, work the findings, guard AI prompts and report regulated data.



Data Security findings with sensitive records by PCI, PII and PHI. help.accuknox.com/getting-started/dspm-overview

- | | | | | | |
|----|--|----|----|---|----|
| 01 | Discover every store
Scope sources and scan public buckets | 05 | 04 | Triage findings
Severity, sensitivity and SLA | 08 |
| 02 | Classify by content
Country packs, confidence and allow list | 06 | 05 | Guard AI prompts
Mask PII and block secrets | 09 |
| 03 | Close exposed stores
Public access and encryption | 07 | 06 | Report for compliance
Regulated data by framework | 10 |

Scan every data store, not only the **known ones**

Include S3 Buckets

☒ Select S3 buckets by Tags

```
env = prod
env = stage
team=*
*=customer
```

Enter tag name / tag pattern to include in each row. e.g env=prod, env=*, *=stage

☒ Select S3 Buckets by Name

```
*customer
```

Enter folder name / bucket name / pattern to include in each row. (e.g. finance, *finance)

☒ Scan Publicly Exposed buckets

All the publicly exposed buckets will be scanned for sensitive assets. Doesn't restrict to name or pattern or path if specified above.

☒ Allow Accuknox AI to scan results to reduce false positives

Scope each S3 source by tag and name pattern, then scan every public bucket whatever its name.

HOW ACCUKNOX CLOSES THE GAP

The scanner runs as a VM or Kubernetes CronJob in your account. It reads a sample each night and sends one findings file per data store. [Onboard the DSPM scanner](#)

Scope an S3 source. help.accuknox.com/getting-started/dspm-overview

DO

- Turn on Data Security for each AWS account and Azure subscription, then add each store as a source.
- Select S3 buckets by tag and by name pattern, such as **env = prod** or ***customer**.
- Check **Scan Publicly Exposed buckets**. It scans every public bucket, even outside your patterns.
- Run one scanner per region, because a scanner never reads data in another region.

DON'T

- Don't scan only the buckets on a team's list. New copies land outside that list.
- Don't give the scanner write access. Every grant it needs is read only.
- Don't assume full coverage. Google Cloud Storage, NFS shares, Oracle and Snowflake are not supported yet.

Classify by content, not by **store name**

The screenshot shows the 'customer_salesrecords' asset in the AccuKnox console. It lists various files and the sensitive data detected within them. The 'Sensitive Data' column shows tags like 'Aadhar Card', 'Credit Card', 'Bank Account Number', 'Patient ID', 'Debit Card', 'Phone Number', 'Driving License', and 'Health Insurance' with associated confidence scores and counts.

File	File Type	Path	Sensitive Data
table 1.xls	Spreadsheet	../filepath/	Aadhar Card 2 +3
500col - Sheet1 (1).csv	Spreadsheet	../filepath/	Credit Card 2 +2
table 1.xls	Document	../filepath/	Bank Account Number 2 +1
table 1.xls	Document	../filepath/	Patient ID 2 +23
table 1.xls	Word Document	../filepath/	Debit Card 2 +1
table 1.xls	Word Document	../filepath/	Phone Number 2 +2
table 1.xls	Word Document	../filepath/	Driving License 2 +5
table 1.xls	Document	../filepath/	Health Insurance 2 +2

The scanner reads each file and row, then tags what it finds, such as Aadhaar, card and bank account numbers.

HOW ACCUKNOX CLOSES THE GAP

283 data classes cover PII, PHI, financial data, credentials and national IDs, each with a confidence tier. [See what the scanner detects](#)

Evidence per file in one asset. help.accuknox.com/getting-started/dspm-overview

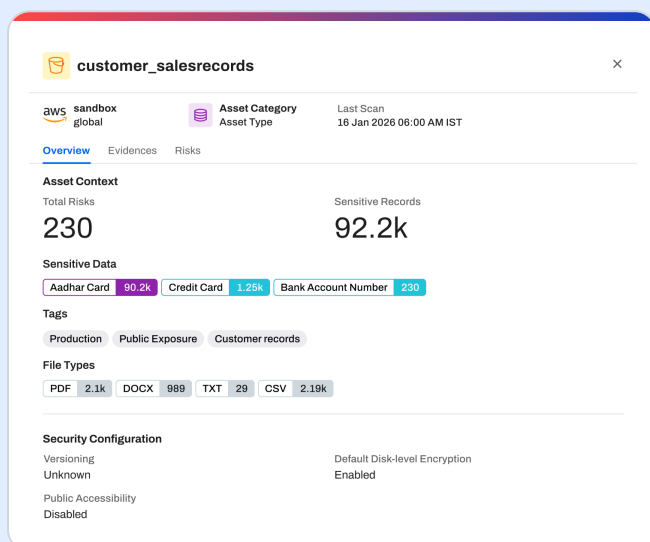
DO

- Enable the country packs for the countries you operate in. They decide which national IDs and phone formats match.
- Keep the confidence floor at **Likely**. Raise it to **Very likely** for fewer, stronger findings.
- Put public phone numbers, test accounts and sample data on the allow list.
- Let AccuKnox AI review the results to cut false positives.

DON'T

- Don't trust a bucket name or tag to say what the bucket holds.
- Don't ignore a value in the console only. Add it to the allow list, or it returns on the next run.
- Don't keep detectors you never need. Switch them off to cut noise.

Close public and unencrypted stores **first**



Asset overview with security configuration.
help.accuknox.com/getting-started/dspm-overview

Each asset shows its sensitive records beside its encryption and public access settings, so you fix the riskiest stores first.

HOW ACCUKNOX CLOSES THE GAP

DSPM shows which store holds the data. CSPM flags the public S3 bucket or the unencrypted volume behind it. **Fix S3 public exposure**

DO

- Filter for the findings **A data asset is public** and **An unencrypted data asset can be accessed by identities**.
- Open each asset and read **Security Configuration** for encryption and public access.
- Block public access on each S3 bucket that holds sensitive records, then confirm the finding clears.
- Turn on default encryption for stores that hold PII, PHI or card data.

DON'T

- Don't fix exposure in the order findings arrived. Rank by sensitive record count.
- Don't leave a public copy behind after you lock down the main store.
- Don't grant broad read roles to reach a store faster. Check which identities can already read it.

Work findings by severity, sensitivity and SLA

Each finding carries a severity, an SLA window and a sensitivity label, so the queue has an order before anyone reads it.

AWS access key ID in plain text Critical 📄 🔗 ×

1 Age: 0 day | Severity: ● Critical | SLA: 10 days | Sensitivity: Restricted | Tickets Created: 0

2 Description | Solution | Classification | Data Matches | Other Info | Raw >

An access key ID identifies a long-term AWS credential and is almost always stored alongside its secret key. The CIS AWS Foundations Benchmark requires long-term keys to be minimized and rotated.

3 🔗 Create Ticket 🧠 Ask AI

Asset: accuknox
Asset Type: aws_s3_bucket

4 Status: 🔴 Active

A Critical finding with SLA and sensitivity. help.accuknox.com/getting-started/dspm-onboarding

DO

- Start with Critical and Restricted findings, then the largest match counts, then the oldest against SLA.
- Raise a ticket in your tracker from the finding with **Create Ticket**.
- Follow the **Solution** tab for the remediation and its references.
- Confirm the fix when **Last detected** stops advancing after the data is masked, moved or deleted.

DON'T

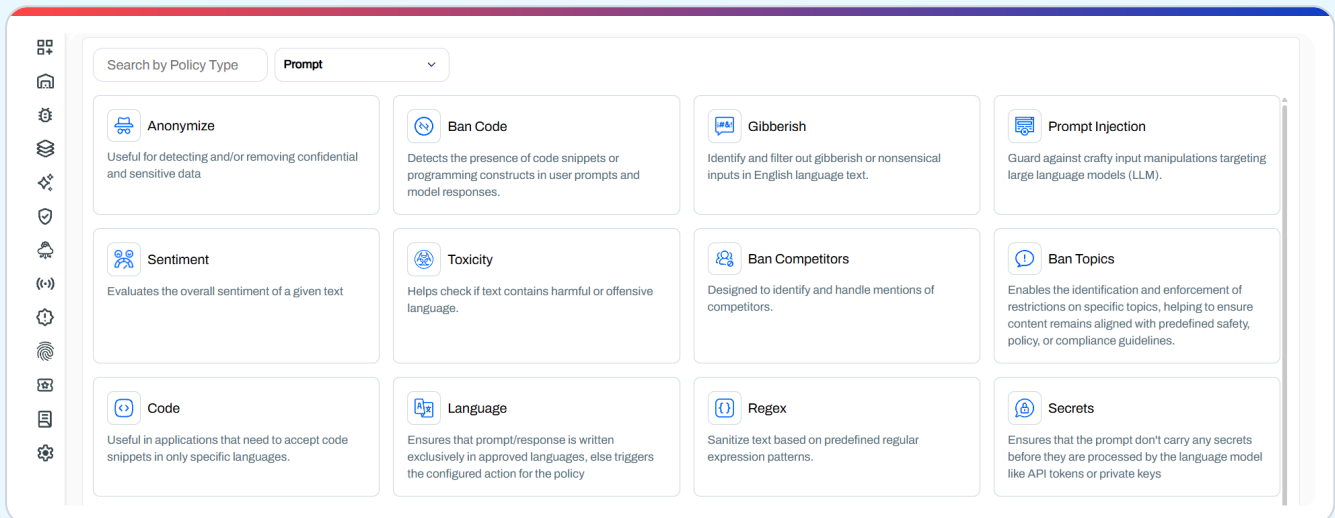
- Don't copy raw values into a ticket. **Data Matches** already masks each value to its last four characters.
- Don't turn on **Ignored** unless you confirmed the value is public or test data.
- Don't let a Critical finding pass its SLA. The SLA for this Critical finding is 10 days.

HOW ACCUKNOX CLOSES THE GAP

Ask AI explains a finding, and the Classification tab lists its CWE, MITRE ATT&CK and compliance mapping. [Review DSPM findings](#)

Stop sensitive data at the **AI prompt**

The Prompt Firewall sits inline between users and the LLM, and masks or blocks sensitive data in both directions.



Prompt Firewall policy types. help.accuknox.com/use-cases/prompt-firewall-overview

DO

- Turn on **Anonymize** to mask names, SSNs, emails, medical records and card numbers.
- Turn on **Secrets** to block API keys, tokens and passwords before the LLM sees them.
- Inspect responses too, so sensitive content never reaches the end user.
- Add **Regex** patterns for internal IDs and custom formats.

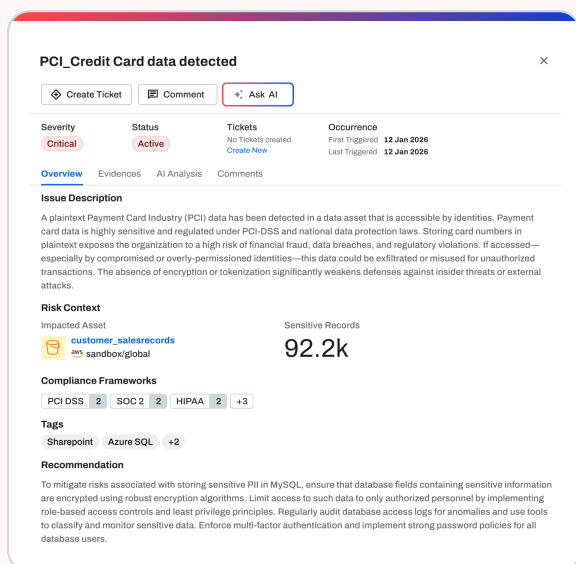
DON'T

- Don't treat the firewall as the only control. Guardrails are probabilistic and miss some attacks.
- Don't let staff paste customer records into unapproved AI tools.
- Don't block on day one. Monitor first, then block once the policy proves itself.

HOW ACCUKNOX CLOSES THE GAP

Every prompt and response passes the firewall, which blocks, sanitizes or monitors it and logs it for audit. [Read the Prompt Firewall guide](#)

Show auditors where regulated data sits



282 of 283 data classes carry the regulation clauses they fall under, from GDPR and PCI DSS to HIPAA and India DPDP.

HOW ACCUKNOX CLOSSES THE GAP

Frameworks include GDPR, UK GDPR, PCI DSS, HIPAA, CPRA, India DPDP, POPIA, PIPEDA and the NIST SP 800 series. [See the compliance mapping](#)

A finding mapped to PCI DSS, SOC 2 and HIPAA.
help.accuknox.com/getting-started/dspm-overview

DO

- Filter findings by framework to list every asset that holds data under it.
- Enable the country packs that match your regulators, because coverage follows the packs.
- Use the **Classification** tab for each class's CWE and MITRE ATT&CK references.
- Run the console on premises or air gapped when data must stay inside your boundary.

DON'T

- Don't present the data map as a controls audit. DSPM shows where regulated data sits, not how well its controls work.
- Don't hand auditors raw values. The console masks each value to its last four characters.
- Don't scan only before the audit. Nightly runs record when each finding cleared.

Find your gap, then take the first step

Read each row. Where the gap is true for you, take the first step this week.

IF THIS IS TRUE	ACCUKNOX CAPABILITY	FIRST STEP
Nobody can list every bucket, database and SaaS app that holds sensitive data	DSPM discovery	Onboard the scanner in each region and add each store as a source
Public buckets are never scanned for their content	Scan Publicly Exposed buckets	Check the option on every S3 source
Findings flag test data and public phone numbers	Confidence floor and allow list	Add known values to the allow list and switch off unused detectors
Sensitive records sit in public or unencrypted stores	DSPM with CSPM	Filter for public and unencrypted asset findings, then fix by record count
Staff paste customer data into AI tools	Prompt Firewall	Turn on Anonymize and Secrets in monitor mode
Auditors ask where regulated data lives	Compliance mapping	Filter findings by framework to list the assets that hold it

See where your sensitive data lives today

Book a demo to watch DSPM scan a data store in its own region and rank the findings it returns.

[Book a demo](#)[Read the DSPM docs](#)

283

data classes, each with a confidence tier

62

country packs for national ID numbers

16

compliance framework groups

2026

Featured in the KuppingerCole CNAPP Leadership Compass

Sources. accuknox.com/platform/dspm and accuknox.com/analyst-recognition